La brecha de control: por qué su empresa necesita un programa de seguridad y gobernanza para IA agéntica

Nov 12, 2026 · @Matias

En pocas palabras: los agentes de IA ya no son un piloto. Leen correos, consultan bases de datos, ejecutan código, operan sistemas financieros y llaman a otros sistemas con credenciales reales. La evidencia de 2025 y 2026 muestra tres cosas: las pérdidas económicas ya se materializaron, la dirección sobrestima cuánto control tiene, y las empresas con más controles pierden sensiblemente menos dinero. Dos estudios recientes de VentureBeat muestran lo mismo desde ángulos distintos: las empresas desplegaron agentes antes de construir los controles para gobernarlos, y lo sabían. La brecha entre lo que la dirección cree que está controlado y lo que realmente lo está es hoy uno de los riesgos operativos más grandes y menos presupuestados de la organización. La gobernanza de agentes no es un costo de cumplimiento: es una decisión financiera.

El costo ya no es hipotético

Indicador	Dato	Fuente
Empresas con pérdidas por riesgos de IA	**99%**; el **64%** perdió más de USD 1 millón	EY Responsible AI Pulse (975 ejecutivos C-level)
Pérdida promedio por empresa afectada	**USD 4,4 millones** (USD 4.300 millones en total entre los encuestados)	EY
Costo de una brecha habilitada por IA	**USD 6 millones**, un millón más que el promedio global de USD 4,99 millones	IBM Cost of a Data Breach 2026
Brechas maliciosas habilitadas por IA	**1 de cada 4**, un **56%** más que el año anterior	IBM
Organizaciones con ataques a sus propios modelos o aplicaciones de IA	**Más del 20%**	IBM
Pérdidas declaradas en denuncias vinculadas a IA (EE.UU., 2025)	**Casi USD 893 millones** en 22.364 denuncias	FBI IC3

El dato más relevante para un directorio es la correlación entre controles y pérdidas. Según EY, las empresas que perdieron **más de USD 10 millones** tenían en promedio **4,5 de 10** controles recomendados; las que perdieron **USD 1 millón o menos**, **6,4**. IBM encontró algo similar del lado de la defensa: las organizaciones que usan IA y automatización en sus operaciones de seguridad redujeron el costo de una brecha en **casi USD 2 millones**.

Los casos recientes muestran cómo se ve esto en la práctica:

- **Mercor**, startup de datos para IA valuada en USD 10.000 millones, fue comprometida a través de un ataque a la cadena de suministro de LiteLLM, una librería de código abierto usada para conectar aplicaciones con modelos. Los atacantes afirman haber robado unos 4 TB de datos, y Meta suspendió sus contratos con la empresa.
- **Step Finance**: según el análisis de Beam AI, tras comprometer dispositivos de ejecutivos, los atacantes usaron agentes de trading con permisos de transferencia sin aprobación para mover entre USD 27 y 30 millones. Se recuperaron USD 4,7 millones y la compañía cerró.
- **Gobierno de México**: un solo atacante, apoyado en herramientas de IA agéntica, vulneró nueve organismos y expuso 195 millones de registros de contribuyentes, según la misma fuente. La región no está al margen de esta tendencia.

La ilusión de control

El dato que debería incomodar a cualquier directorio es este: según el State of AI Agent Security 2026 de Gravitee, que encuestó a 919 ejecutivos y profesionales, el **82% de los ejecutivos cree que sus políticas los protegen** contra acciones no autorizadas de agentes. Sin embargo, el **88% reportó incidentes de seguridad con agentes de IA** en los últimos doce meses, y apenas el **21% tiene visibilidad en tiempo de ejecución** sobre lo que sus agentes hacen.

La expectativa de los propios líderes de seguridad es todavía más elocuente. El Agentic AI Security Report 2026 de Arkose Labs encontró que el **97% espera un incidente material provocado por agentes en los próximos doce meses**, pero solo el **6% del presupuesto de seguridad** está destinado a ese riesgo.

Merritt Baer, CSO de Enkrypt AI y ex Deputy CISO de AWS, lo resume con precisión: lo que muchas empresas aprobaron es *"una interfaz, no el sistema subyacente"*. Se firmó el chatbot; nadie revisó lo que el agente detrás puede alcanzar.

El problema también es de conocimiento en la cúpula: cuando EY pidió a ejecutivos C-level asociar los controles correctos a cinco riesgos de IA, **solo el 12%** respondió bien todo. Y la transparencia es baja: un estudio de MIT FutureTech y la Universidad de Queensland estima que el **62%** de las 1.000 mayores empresas cotizantes no reconoce públicamente ningún riesgo de IA, incluido el **32%** de las 100 más grandes.

Por qué los agentes cambian la ecuación de riesgo

Un agente no es una aplicación más: es una identidad que actúa con privilegios. Elia Zaitsev, CTO de CrowdStrike, advierte que en los registros por defecto es imposible distinguir si un navegador lo maneja una persona o un agente, y que cada agente opera como un usuario privilegiado con tokens OAuth y claves de API.

Los números confirman que la mayoría de las empresas no los trata como identidades:

- Solo el **21,9%** de los equipos trata a los agentes como entidades con identidad propia.
- El **45,6%** todavía usa **claves de API compartidas**.
- El **25,5%** de los agentes desplegados **puede crear otros agentes y asignarles tareas**, abriendo caminos de escalamiento de privilegios que nadie inventarió.

El CEO de CrowdStrike, George Kurtz, documentó el caso de un agente que, al no tener permisos para resolver un problema, eliminó la restricción por su cuenta. A eso se suma la velocidad del adversario: el tiempo de movimiento lateral más rápido registrado es de 27 segundos, y según Ivanti los atacantes hacen ingeniería inversa de los parches en 72 horas. Ningún proceso de aprobación manual compite con eso si no hay controles automáticos de por medio.

El entorno agrava la exposición. El Verizon DBIR 2026, basado en más de 22.000 brechas confirmadas, muestra que los terceros intervienen en el **48%** de las brechas, que solo el **26%** de las vulnerabilidades críticas se remedió por completo en 2025 y que el **45%** de los empleados ya usa IA con regularidad en dispositivos corporativos, frente al 15% del año anterior, mayormente con cuentas no corporativas.

La evidencia: compartir credenciales cuesta caro

El relevamiento de VentureBeat Research de junio de 2026 (573 encuestados en empresas de más de 100 empleados) aporta la correlación más clara. El **69% de las empresas permite que al menos algunos agentes compartan credenciales**. Entre ellas, el **63,5% reportó un incidente o un casi-incidente**. En las empresas donde cada agente tiene una identidad propia y acotada, la cifra cae al **40,9%**. Las muestras de esos subgrupos son chicas y el estudio es autoseleccionado, pero la dirección es inequívoca: la identidad por agente es el control más barato con mayor retorno. El detalle está en el informe de Seguridad e Identidad Agéntica.

La autonomía crece más rápido que la confianza

El segundo gran hallazgo es que las empresas están quitando a las personas del circuito antes de poder verificar a las máquinas:

- **Dos tercios** ya permiten, o planean permitir en un año, **cambios en producción basados solo en evaluaciones automáticas**. Pero apenas el **5% confía plenamente** en esas evaluaciones.
- **Cerca de la mitad** lanzó un agente que **pasó sus evaluaciones internas y luego falló frente a clientes** en el último año (informe de Confiabilidad y Evals).
- El **57%** rastreó en los últimos seis meses una respuesta **segura de sí misma y equivocada** a contexto de negocio faltante o inconsistente (informe de Capas de Contexto).

Hay también un dato que ordena la conversación: el **71%** dice que **un cuarto o menos** de lo que llama "agentes" puede completar trabajo de varios pasos por sí solo (informe de Orquestación Agéntica). Esto es una buena noticia: no todo necesita el máximo nivel de control. Pero exige un inventario honesto para saber cuáles sí.

La mayoría está atascada en la etapa uno

VentureBeat propone un marco de madurez en tres etapas, alineado con el OWASP Top 10 for Agentic Applications 2026:

Etapa	Qué resuelve	Controles clave
1. Observar	Saber qué hacen los agentes	Registro de llamadas a herramientas en el SIEM, líneas de base de comportamiento, pruebas con canary tokens
2. Hacer cumplir	Convertir la observación en límites	Identidades acotadas por agente, aprobación para operaciones de escritura, escaneo de servidores MCP, revocación de claves compartidas
3. Aislar	Contener el daño cuando los guardrails fallan	Ejecución en sandbox, delegación entre agentes con zero trust, firma humana para cambios de seguridad, apagado de emergencia (kill switch)

La mayoría de las empresas monitorea sin hacer cumplir, y hace cumplir sin aislar, mientras sus agentes ya necesitan controles de etapa dos o tres. La encuesta de madurez de confianza en IA 2026 de McKinsey ubica la madurez promedio en **2,3 sobre 4** y estima que el **70% no completó la transición** a la etapa tres. Y un punto clave para la estrategia: los guardrails del modelo no alcanzan, porque restringen instrucciones, no lo que un agente comprometido puede tocar. Kazdan y colegas lograron saltear los guardrails de modelos líderes en más de la mitad de los intentos.

El reloj regulatorio y de mercado ya corre

Las obligaciones de supervisión humana del Artículo 14 de la Ley de IA de la UE rigen desde el 2 de agosto de 2026, y son relevantes para toda empresa que opere con Europa. Sectores como salud y finanzas suman exposición específica: el Informe de Supervisión 2026 de FINRA ya aborda la IA generativa, y las multas HIPAA por negligencia deliberada llegan a USD 2,19 millones por categoría de infracción por año. No es casual que salud registre la tasa de incidentes más alta: **92,7%**.

Al mismo tiempo, el mercado está abierto. Entre el **57% y el 68%** de las empresas planea cambiar o sumar proveedores en las capas de control dentro de un año, y ninguna capa tiene un líder consolidado. Además, los controles nativos de cada proveedor solo aplican dentro de su propio entorno. Quien defina ahora su arquitectura de gobernanza, independiente del proveedor, decide en lugar de heredar decisiones.

Qué pedirle a su equipo: un plan de 90 días

Días 1 a 30: inventario y línea de base. Un responsable con nombre y apellido para cada agente. Registro de todas las llamadas a herramientas y acciones. Revocación de claves de API compartidas. Monitoreo de solo lectura, escaneo de servidores MCP y revisión de los componentes de terceros que usan los agentes.

Días 31 a 60: hacer cumplir y acotar. Identidad propia y acotada por agente, empezando por los que tocan producción o dinero. Flujos de aprobación humana para toda operación de escritura. Integración de registros al SIEM y ejercicios de simulación.

Días 61 a 90: aislar y probar. Entornos aislados (sandbox) para cargas de alto riesgo: datos personales, de salud y transacciones financieras. Mínimo privilegio por sesión. Firma humana para la delegación entre agentes. Pruebas de ataque (red teaming) sobre el perímetro de aislamiento.

En paralelo, dos reglas de gobierno: **no quitar la revisión humana de ningún flujo** hasta validar las evaluaciones contra resultados reales de producción, y **gobernar las métricas y datos de negocio** de los que responden los agentes antes de escalarlos.

La pregunta para el próximo directorio

Un programa de seguridad y gobernanza agéntica no frena la adopción: es lo que permite escalarla sin apostar la reputación en cada despliegue. La prueba es simple. Si hoy no es posible responder con certeza **cuántos agentes tiene la empresa, qué pueden tocar, con qué credenciales y si pueden detenerse en segundos**, el riesgo no es teórico. Según los

datos, para casi nueve de cada diez empresas ya se materializó, y para casi todas las grandes empresas ya tiene un costo. La diferencia entre perder uno o diez millones está, en buena medida, en los controles que se decidan hoy.

Fuentes: VentureBeat: The enforcement gap: 88% of enterprises reported AI agent security incidents last year (Louis Columbus, abril 2026) · VentureBeat Research: Where enterprise AI agent governance hasn't caught up (Matt Marshall, julio 2026) · IBM Cost of a Data Breach 2026 · Verizon DBIR 2026 · MIT FutureTech: Unmitigated? · EY Responsible AI Pulse · Beam AI